MediCore · Reporte de seguridad y accesibilidad

Resultados de la corrida 5 de Jenkins, del 2026-11-06. Todas las pruebas se hicieron sobre el ambiente QA local, con datos ficticios.

Resumen

Herramienta	Resultado	Reporte
SonarQube	Quality Gate aprobado, 0 bugs, 0 vulnerabilidades	`reports/sonarqube/`
npm audit	0 vulnerabilidades	`reports/npm-audit/audit.json`
NuGet	0 paquetes vulnerables	`reports/dependency-check/nuget-vulnerable.txt`
Dependency-Check	58 coincidencias, 4 críticas: todas apuntan a servidores, no a las bibliotecas	`reports/dependency-check/`
OWASP ZAP web	0 fallas, 141 reglas aprobadas, 2 advertencias	`reports/zap/zap.html`
OWASP ZAP API	0 fallas, 119 reglas aprobadas, 2 advertencias	`reports/zap/zap-api.html`
Fortify	**No ejecutado**: no hay licencia	`scripts/sec-fortify.sh`
axe-core	14 pantallas, 0 infracciones	`reports/accesibilidad/axe.json`

SonarQube

El Quality Gate "MediCore" exige: 0 vulnerabilidades, seguridad A, confiabilidad B o mejor, mantenibilidad A, cobertura de 60 % o más y duplicación de 3 % o menos. En el código nuevo exige cobertura de 80 % y duplicación de 3 % o menos.

Métrica	Valor
Bugs	0
Vulnerabilidades	0
Code smells	124
Cobertura	74,2 %
Cobertura del código nuevo	80,5 %
Duplicación	0,2 %
Líneas de código	10 637

La puerta sí rechazó una corrida. En la corrida 2 falló por 49 % de cobertura y 9,3 % de duplicación en el código nuevo. Se compartió la lectura de errores entre web y móvil, se agregaron 4 pruebas y los sembradores de datos ficticios salieron del cálculo de cobertura.

Revisión de los 29 puntos sensibles

Sonar los marca para revisión humana. Se revisaron uno por uno, pero el estado en el servidor sigue como "por revisar".

Cantidad	Ubicación	Conclusión
12	SQL en las pruebas de Cypress	Solo pruebas: preparan datos ficticios en QA
4	Generadores aleatorios en k6, Cypress y scripts	Solo datos de prueba; no se usa para seguridad
2	`IgnoreAntiforgeryToken` en `Error` y `Estado`	Aceptado: páginas de solo lectura, sin datos ni cambios
3	Imágenes de CI y Android corren como root	Aceptado: herramientas locales, nunca en producción
5	Terraform: IP pública, acceso público, cifrado e identidad	**Revisar antes de aplicar en Azure**
3	HTTP en k6, redirecciones en la imagen de Jenkins y contraseña en la colección	Red interna de QA y variable de entorno, sin secreto real

Dependencias

Las 58 coincidencias de Dependency-Check salen de `Npgsql.EntityFrameworkCore.PostgreSQL.dll` y `StackExchange.Redis.dll`. La herramienta confundió estas bibliotecas cliente con los servidores PostgreSQL y Redis.

Las 4 críticas se aceptaron en `ci/riesgos-aceptados.json`, con motivo:

CVE	Afecta a	Por qué no aplica
CVE-2018-1115	PostgreSQL servidor	QA usa PostgreSQL 17.11
CVE-2018-16850	PostgreSQL 10 y 11	QA usa PostgreSQL 17.11
CVE-2019-10211	Instalador de PostgreSQL en Windows	QA usa imagen Linux
CVE-2025-49844	Redis servidor, corregido en 7.4.6	QA usa Redis 7.4.12

Lo que no se descartó: el servidor sí es software que corremos. Las coincidencias CVE-2026-25243 y CVE-2026-23631 figuran hasta Redis 8.6.3, y QA usa 7.4.12. Ambas requieren un atacante ya autenticado en Redis. Redis corre en una red interna con contraseña. Queda como riesgo residual: hay que revisar el aviso oficial de Redis y actualizar la imagen antes de producción.

OWASP ZAP

Se analizó la web con un escaneo activo acotado. La API se analizó cinco veces con su contrato OpenAPI, una por rol: Laboratorio, Recepción, Médico, Paciente y Administrador. Cada análisis usa una sesión real, identificadores reales de QA y cuerpos válidos, para pasar la validación y llegar a la lógica clínica. Se excluyen cerrar sesión, renovar sesión y cambiar roles, para no perder la sesión ni alterar las cuentas de prueba.

Cobertura medida: `reports/zap/cobertura-api.json` cuenta, con el registro del proxy, las respuestas por ruta y rol. 40 de las 45 operaciones del contrato respondieron con éxito al menos una vez, y ninguna petición produjo un error 500. Las 5 restantes son las 3 excluidas y las 2 rutas de salud, que no se cuentan en la medición.

Rol	Rutas probadas	Con respuesta exitosa	Errores 500
Laboratorio	87	13	0
Recepción	84	15	0
Médico	99	28	0

Rol	Rutas probadas	Con respuesta exitosa	Errores 500
Paciente	99	30	0
Administrador	85	26	0

Las rutas probadas incluyen variantes que genera ZAP, por eso superan a las del contrato.

Límite: ZAP busca fallas técnicas conocidas. No demuestra que un usuario no pueda leer datos ajenos; eso lo cubren `ClinicalApiTests`, `LaboratoryApiTests` e Insomnia. QA corre sin HTTPS.

Alerta	Dónde	Decisión
HTTP Only Site	Web	QA local sin HTTPS. En Azure se usa HTTPS
COEP faltante	Web	Aceptada en QA. Revisar con HTTPS
Unexpected Content-Type	API	Falso positivo: rutas fuera de la API
Private IP Disclosure	API	Es la IP interna registrada en la auditoría

Defectos corregidos:

- **HZ-01:** un carácter nulo provocaba un error 500. Ahora responde 400, y hay una prueba de regresión.
- **HZ-02:** se agregaron las cabeceras `Permissions-Policy` y `Cross-Origin-Resource-Policy`.

Controles de la aplicación

Tema del documento	Evidencia	Resultado
RBAC	`IdentityApiTests`, Insomnia, Cypress `acceso-permisos`	Aprobado
Autorización por recurso	`ClinicalApiTests`, `LaboratoryApiTests`, Insomnia	Aprobado
Datos sensibles	Pruebas de auditoría y bitácoras	Aprobado
Sesiones	JWT de 15 minutos, refresco de un solo uso, bloqueo tras 5 intentos	Aprobado
API Security	Validación, límite por IP, cabeceras, ZAP con 5 roles	Aprobado
Trazabilidad	`audit_entries`, `GET /api/audit`	Aprobado

Accesibilidad

`accesibilidad-axe.cy.js` analiza 14 pantallas con axe-core 4.10.3 y reglas WCAG 2.0 y 2.1, niveles A y AA.

- **Resultado:** 0 infracciones.
- **Defecto corregido (HA-01):** el calendario tenía contraste insuficiente.
- **Límite:** axe no sustituye la revisión con lector de pantalla ni a las personas de la prueba de usabilidad. Solo cubre lo que se puede detectar de forma automática.

Pendientes

1. Ejecutar Fortify si se consigue licencia. Es un entregable exigido.
2. Revisar los 5 puntos de Terraform antes de aplicar en Azure.
3. Revisar los avisos de Redis y actualizar la imagen antes de producción.